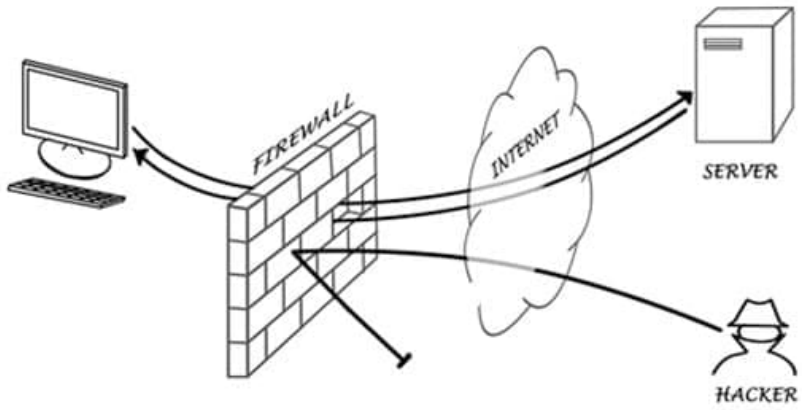
Network Security: Firewall, IDS, IPS

Cyber Security (NS)

Course Instructor: Hafiz Usama Ishtiaq

Firewall

- A Firewall is a network security device that monitors and filters incoming and outgoing network traffic based on an organization's previously established security policies. At its most basic, a firewall is essentially the barrier that sits between a private internal network and the public Internet. A firewall's main purpose is to allow non-threatening traffic in and to keep dangerous traffic out.



The Need for Firewalls

- Internet connectivity is vital for organizations.
  - However, it also poses a threat.
- Firewalls are effective for protecting LANs.
  - They provide protection at a single point instead of on every computer within the LAN.
- Firewalls are placed between the premises network and the Internet to establish a controlled link.
- They serve as a perimeter defense.
  - Firewalls act as a single choke point to enforce security measures and enable auditing.
  - They create insulation between internal systems and external networks.

Firewall Characteristics

Design Goals:

- All internal-to-external traffic is routed through the firewall.
- Only authorized traffic, as per the local security policy, is permitted to pass through..

General Techniques:

- **Service control:** Filtering based on IP address and port number.
- **Direction control:** Controlling traffic flow to and from the internal LAN and external Internet.
- **User control:** Managing access based on user categorization (e.g., student vs. faculty).
- **Behavior control:** Filtering emails to identify and block spam.

Capabilities

- Defines a single choke point.
- Provides a centralized location for monitoring security events.
- Offers a convenient platform for non-security related Internet functions.
- Can serve as a platform for VPN endpoint.

Limitations

- Cannot protect against attacks bypassing the firewall.
- May not provide complete protection against internal threats.
- Improperly secured wireless LAN can be accessed from outside the organization.
- Devices such as laptops, phones, or USB drives may get infected outside the corporate network and then used internally.

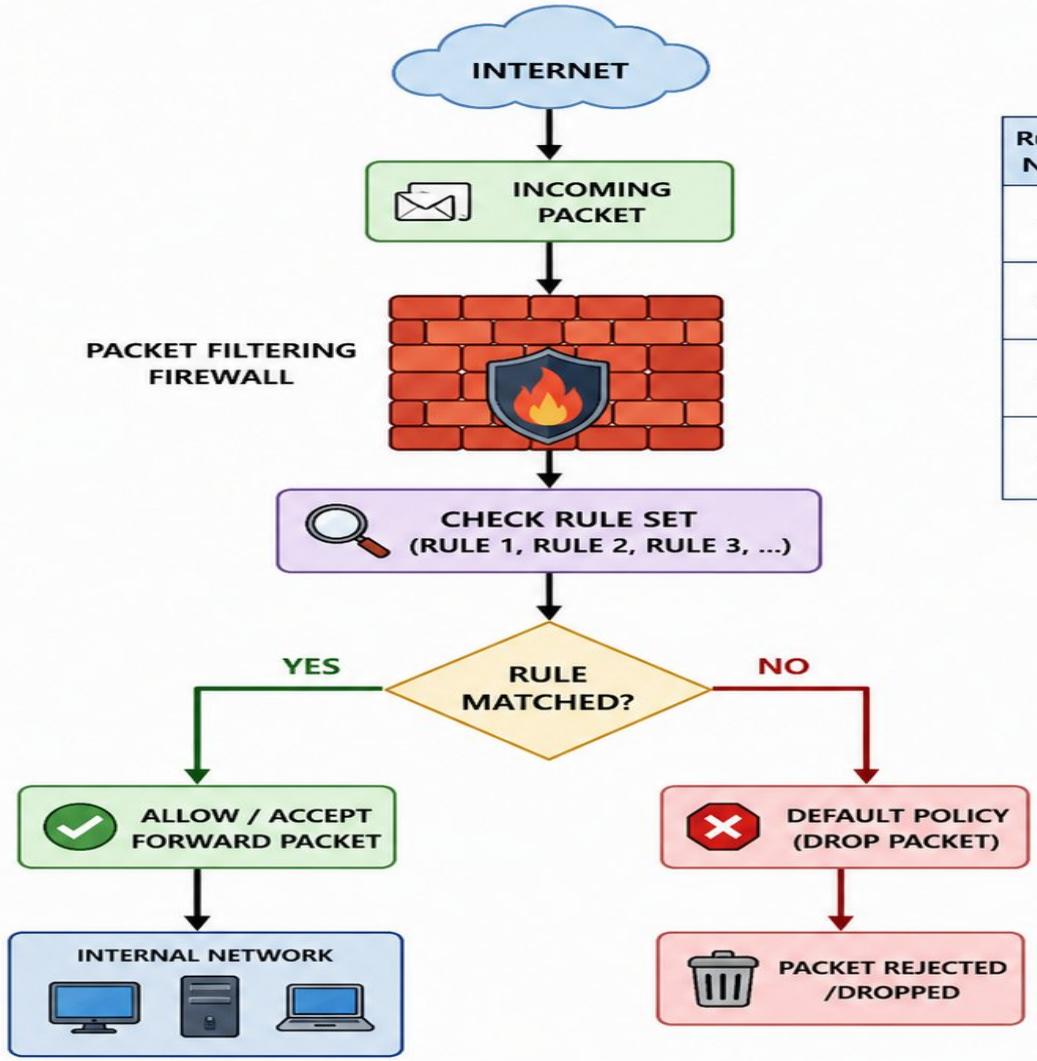
Types of Firewalls

- **Packet Filtering:** Accepts or rejects packets based on protocol headers.
- **Stateful Packet Inspection:** Adds state information to a packet-filtering firewall by keeping track of previous events.
- **Application Proxy:** Acts as a relay for application traffic.
- **Circuit-level Proxy:** Acts as a relay for transport connections.
  - Firewall implementation is typically done on a router.
  - The router may perform other functions, both security-related (e.g., VPN endpoint) and non-security-related (e.g., accounting, NAT).

Packet Filtering Firewall

- Security policy is implemented using a set of rules.
- Rules define the criteria for determining which packets are allowed to pass through the firewall.
- Firewalls inspect each incoming packet in all directions and compare it against the rule set (no context).
- Based on a matching rule, the firewall takes appropriate action on the packet.
- Default policies are defined for packets that do not match any rule.
  - Accept (allow, forward)
  - Drop (reject, discard) - recommended

PACKET FILTERING FIREWALL ARCHITECTURE



EXAMPLE RULE SET

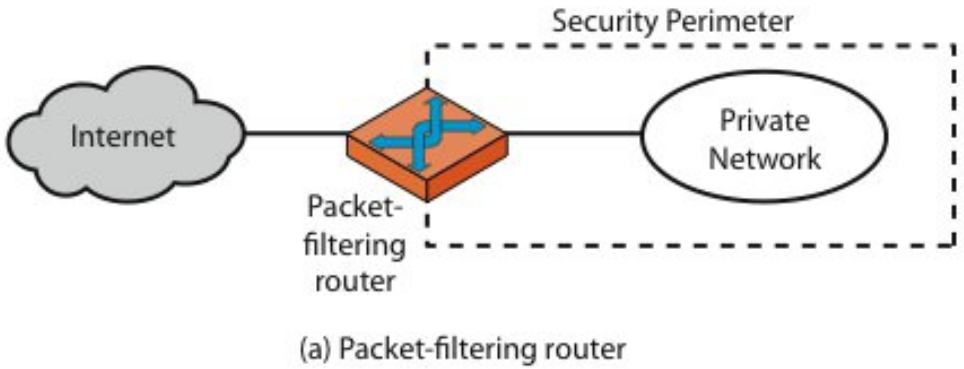
Rule No.	Source IP	Destination IP	Protocol / Port	Action
1	Any	Any	TCP Port 80 (HTTP)	ALLOW
2	Any	Any	TCP Port 443 (HTTPS)	ALLOW
3	Any	Any	TCP Port 23 (Telnet)	DENY
4	Any	Any	Any Other Traffic	DENY

HOW IT WORKS

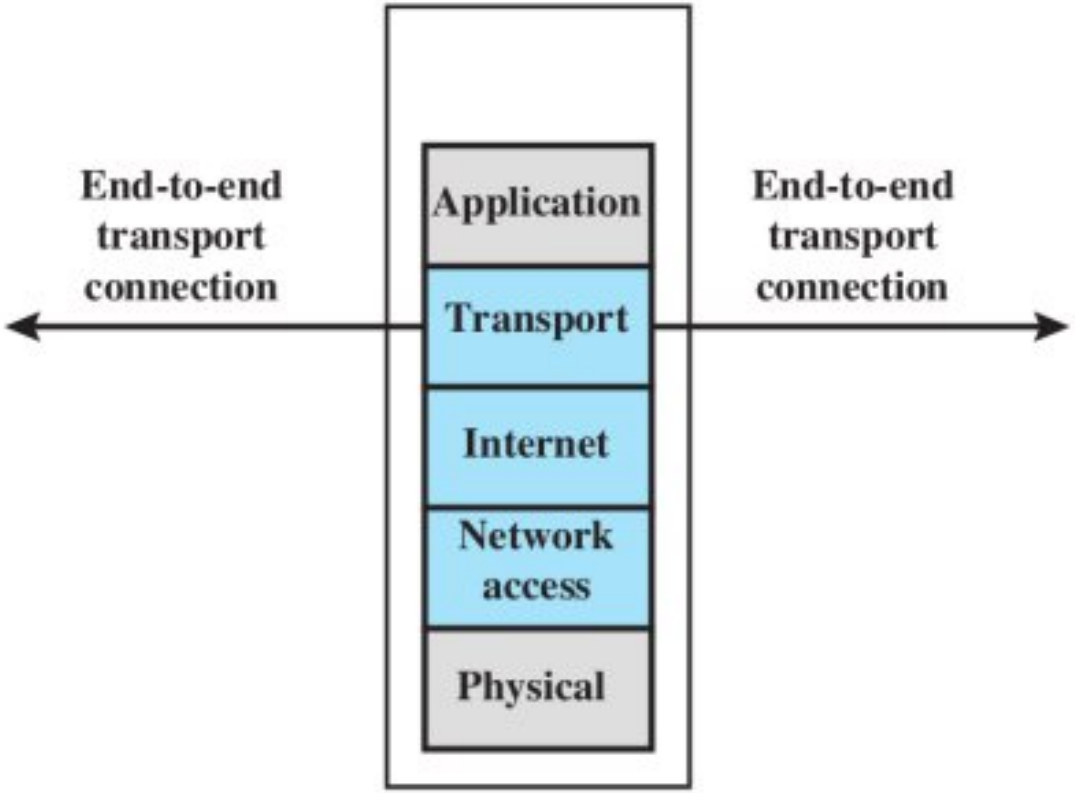
1. Packet arrives from the Internet.
2. Firewall checks the packet against the rule set from top to bottom.
3. If a rule matches, the action (ALLOW or DENY) is applied.
4. If no rule matches, the default policy is applied (usually DROP).

SUMMARY: Packet Filtering Firewall examines every packet and compares it with a set of rules. If a match is found, it allows or blocks the packet. If no match is found, it applies the default policy (usually to drop the packet for security).

Packet Filtering Firewall



(a) Packet-filtering router



Packet Filtering Rules

Packet Information:

- IP address: Identifies the host or network.
- Port number: Identifies the server, such as web (80) or email (25).
- Protocol number: Identifies the transport protocol, such as TCP or UDP.
- Firewall interface: Identifies the immediate source or destination within the firewall.
- Other packet header fields: Includes additional fields related to transport, network, and data link layers.

Packet Filtering Rules

Rules:

- Rules are defined based on packet information and direction.
- Wildcards (*) can be used in rules to match multiple values.
- Actions in rules typically involve accepting or dropping packets.
- The list of rules is processed sequentially, following the defined order.

Screening Policy Actions

- Forward
  - The package is forwarded to the intended recipient
- Drop
  - The packages is dropped (without notification)
- Reject
  - The package is rejected (with notification)
- Log
  - The packages appearance is logged (to be combined)
- Alarm
  - The packages appearance triggers an alarm (to be combined)

Packet Filtering Rules – Examples

Allow HTTP (web) traffic from any source to the internal server:

Source IP: Any

Destination IP: IP address of the internal server

Protocol: TCP

Destination Port: 80 (HTTP)

Action: Accept

Allow outgoing DNS (Domain Name System) requests:

Source IP: Internal network subnet

Destination IP: Any

Protocol: UDP

Destination Port: 53 (DNS)

Action: Accept

Allow FTP (File Transfer Protocol) traffic for a specific range of ports:

Source IP: Any

Destination IP: Internal FTP server IP address

Protocol: TCP

Destination Port Range: 50000-50100

Action: Accept

Deny all inbound SSH (Secure Shell) traffic:

Source IP: Any

Destination IP: Firewall's external IP address

Protocol: TCP

Destination Port: 22 (SSH)

Action: Drop

Block inbound ICMP (Internet Control Message Protocol) ping requests:

Source IP: Any

Destination IP: Firewall's external IP address

Protocol: ICMP

ICMP Type: 8 (Echo Request)

Action: Drop

Block inbound SMTP (Simple Mail Transfer Protocol) traffic:

Source IP: Any

Destination IP: Firewall's external IP address

Protocol: TCP

Destination Port: 25 (SMTP)

Action: Drop

Example Packet Filtering Firewalls

- Software:
  - In operating systems: iptables (Linux), ipfw (Mac OSX), pf (BSD), Windows Firewall
  - Standalone software: Comodo, Kaspersky, Norton, ZoneAlarm, Check Point, etc.
- Appliances:
  - Firewall included in most consumer and enterprise routers
  - Dedicated hardware: Cisco ASA/PIX, Dell SonicWALL, HP, Barracuda, Juniper, etc.
  - Dedicated software distributions: pfSense, Monowall, Smoothwall, ClearOS, Untangle, IPCop, etc.

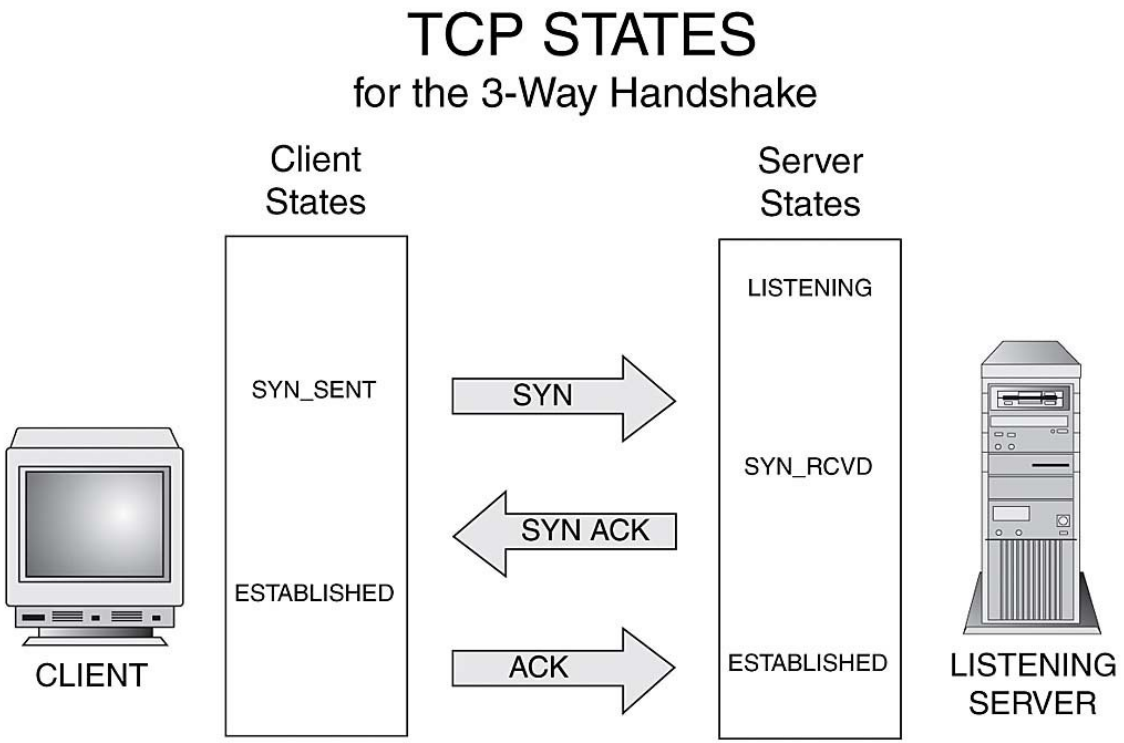
Issues with Packet Filtering Firewalls

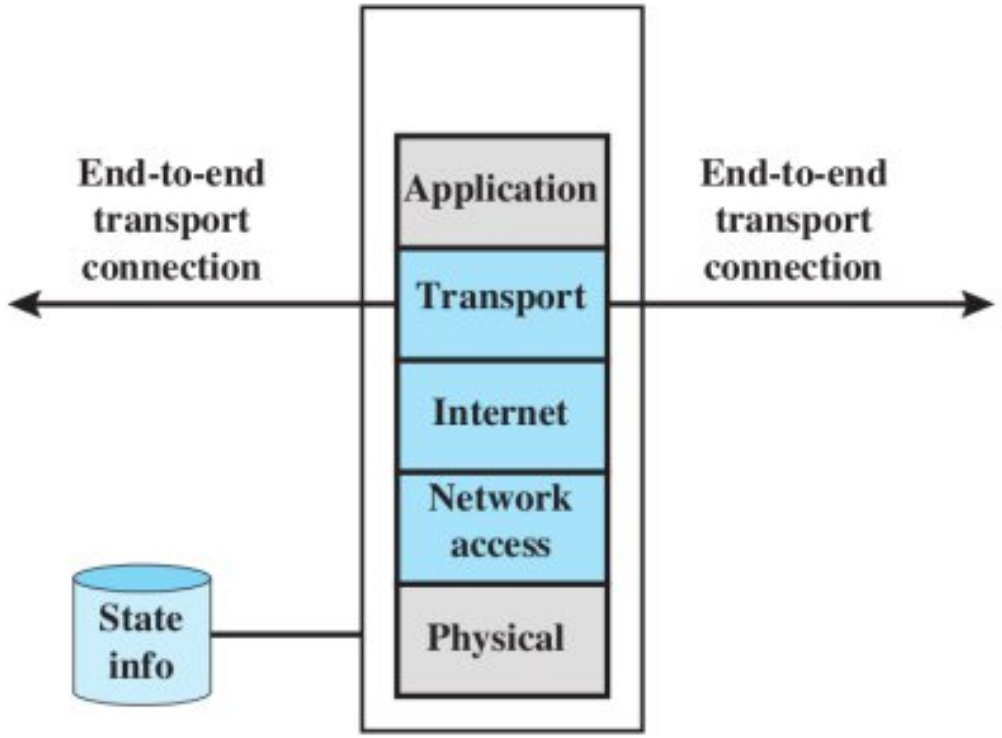
- Advantages of Packet Filtering Firewalls:
  - Simplicity
  - Transparency to users
  - Very fast operation
- Disadvantages of Packet Filtering Firewalls:
  - Cannot prevent attacks exploiting application-specific vulnerabilities or functions.
  - Limited logging functionality.
  - Lack of support for advanced user authentication.
  - Vulnerability to attacks targeting TCP/IP protocol bugs.
  - Improper configuration can lead to security breaches.

Stateful Packet Inspection

- Traditional packet filtering firewall: Makes decisions based on individual packets without considering past packets (stateless).
- Applications establish connections between client and server, and a group of packets belongs to a connection.
- Defining rules for connections is often easier than for individual packets.
- Stateful Packet Inspection (SPI): An extension of traditional packet filtering firewalls that stores information about past behavior to make decisions.
- Issues with SPI: Requires additional overhead for maintaining state information.

Stateful Packet Inspection





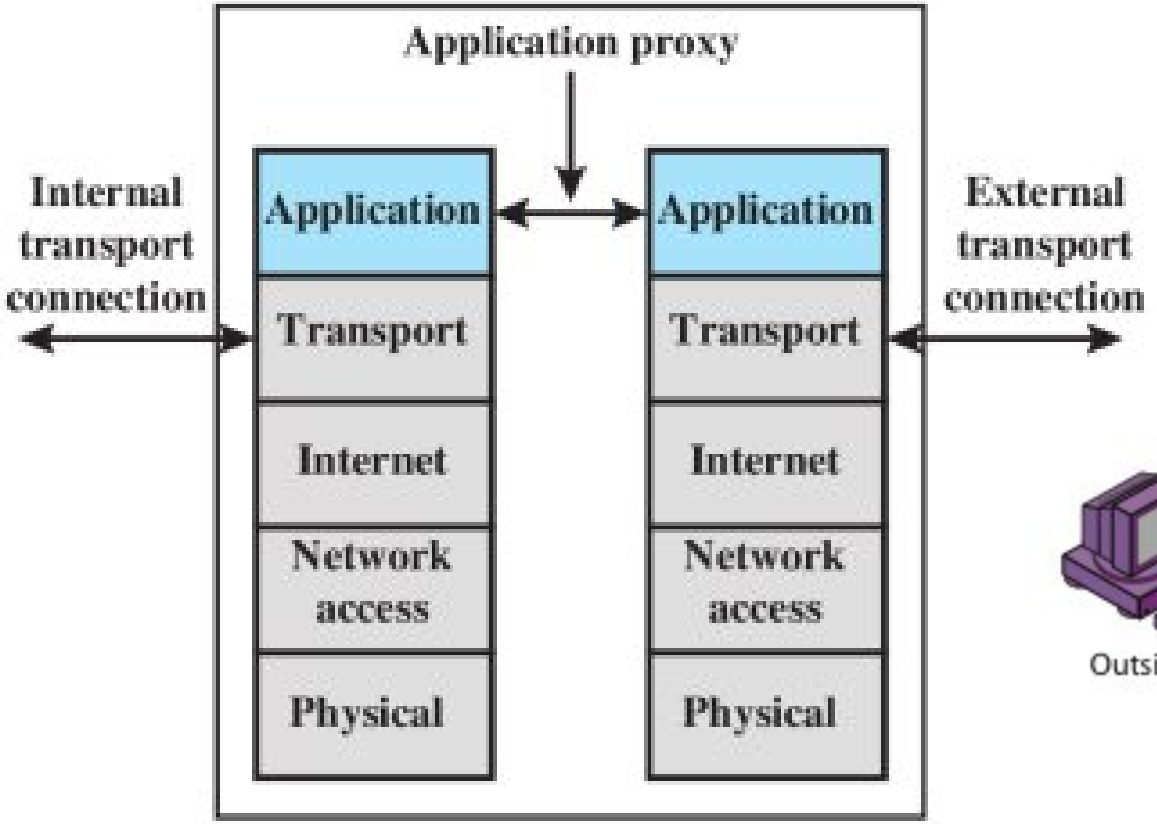
Stateful Packet Inspection

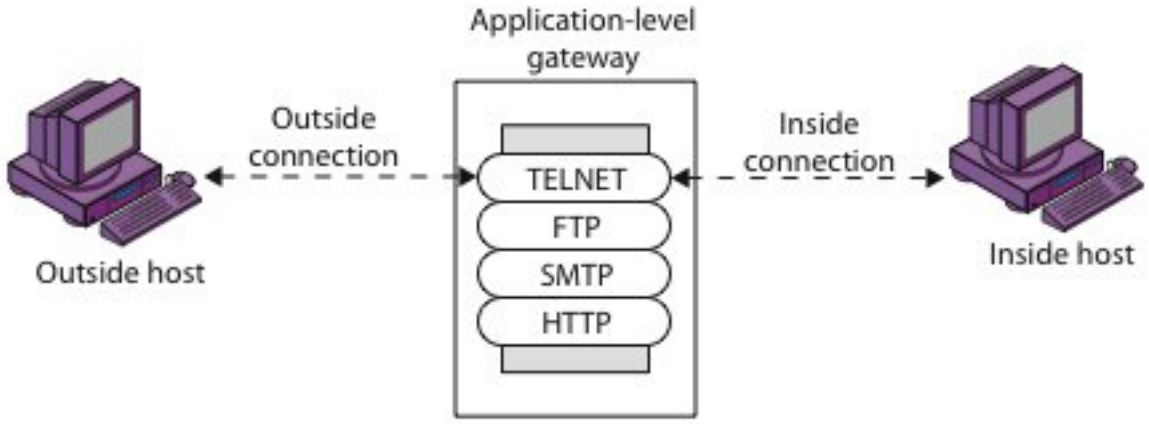
- For connections accepted by packet filtering firewall, record connection information.
  - Source/destination IP address
  - Source/destination port
  - Sequence numbers
  - Connection state (e.g., Established, Closing)
- Packets belonging to existing connections can be accepted without being processed by firewall rules.

Application Proxy

- Also known as Application-level Gateway.
- Relays application-level traffic.
  - User contacts the gateway using a TCP/IP application.
  - The gateway contacts the application on the remote host and relays TCP segments between the server and the user.
- Requires proxy code for each application, which may restrict supported application features.
- Tends to provide higher security compared to packet filters.
- **Disadvantage:** Additional processing overhead on each connection.

Application Proxy



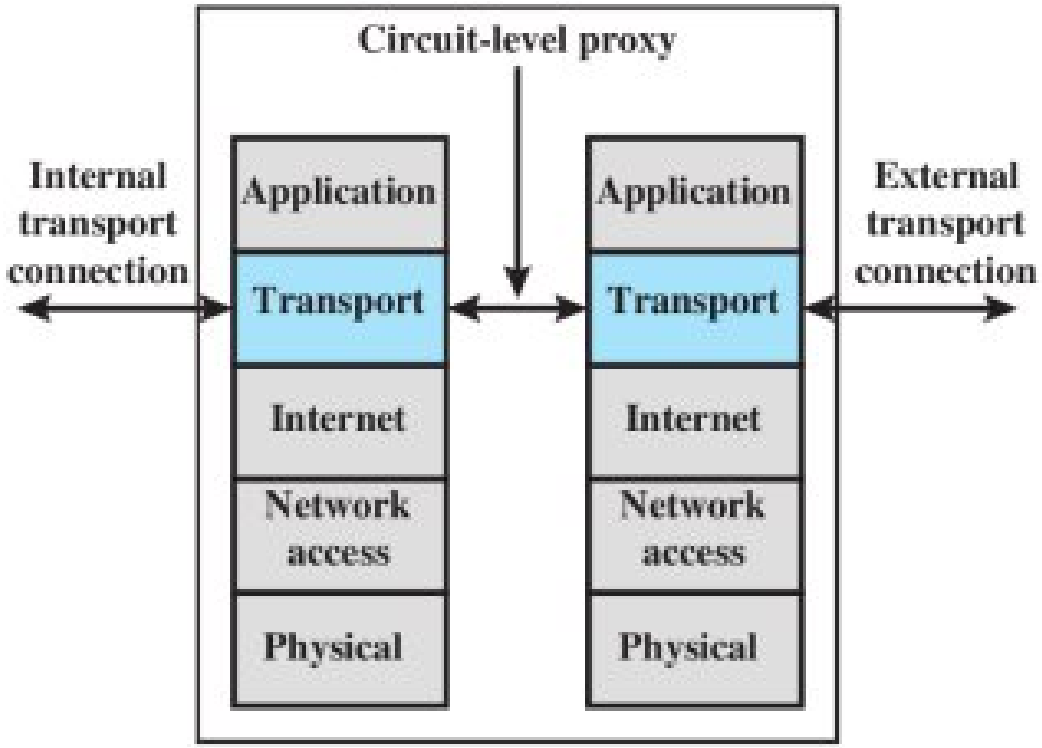


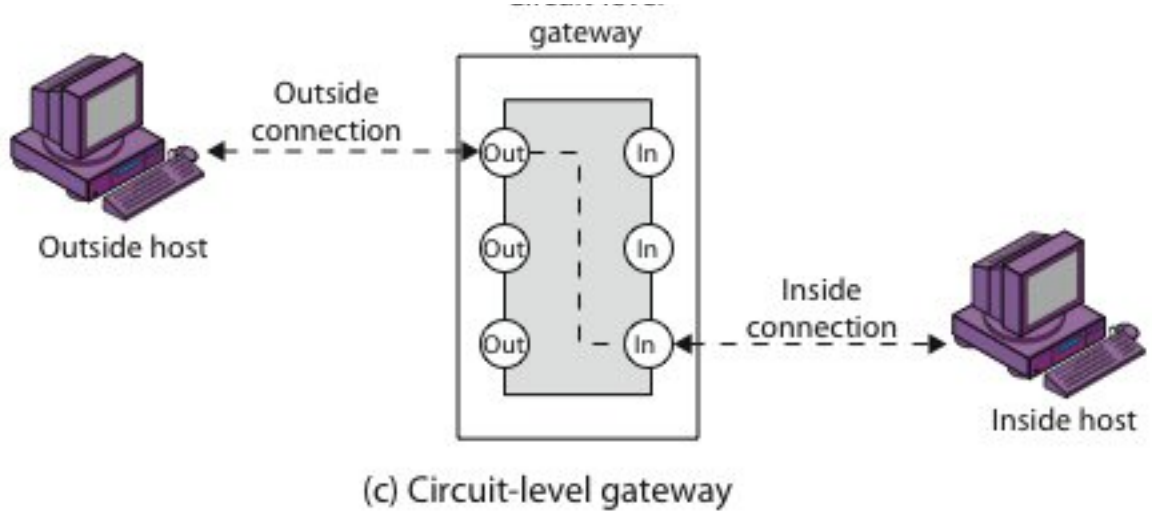
(b) Application-level gateway

Circuit-level Proxy Firewall

- Also known as Circuit-level Gateway.
- Sets up two TCP connections: one between the proxy and a TCP user on an inner host, and another between the proxy and an outside host.
- Relays TCP segments between the two connections without examining the contents.
- Security function involves determining which connections will be allowed.
- Typically used when inside users are trusted, assuming they pose a lower security risk.
- Inbound traffic may be handled by an application-level gateway, while outbound traffic is managed by a circuit-level gateway, resulting in lower overhead.

Circuit-level Proxy Firewall





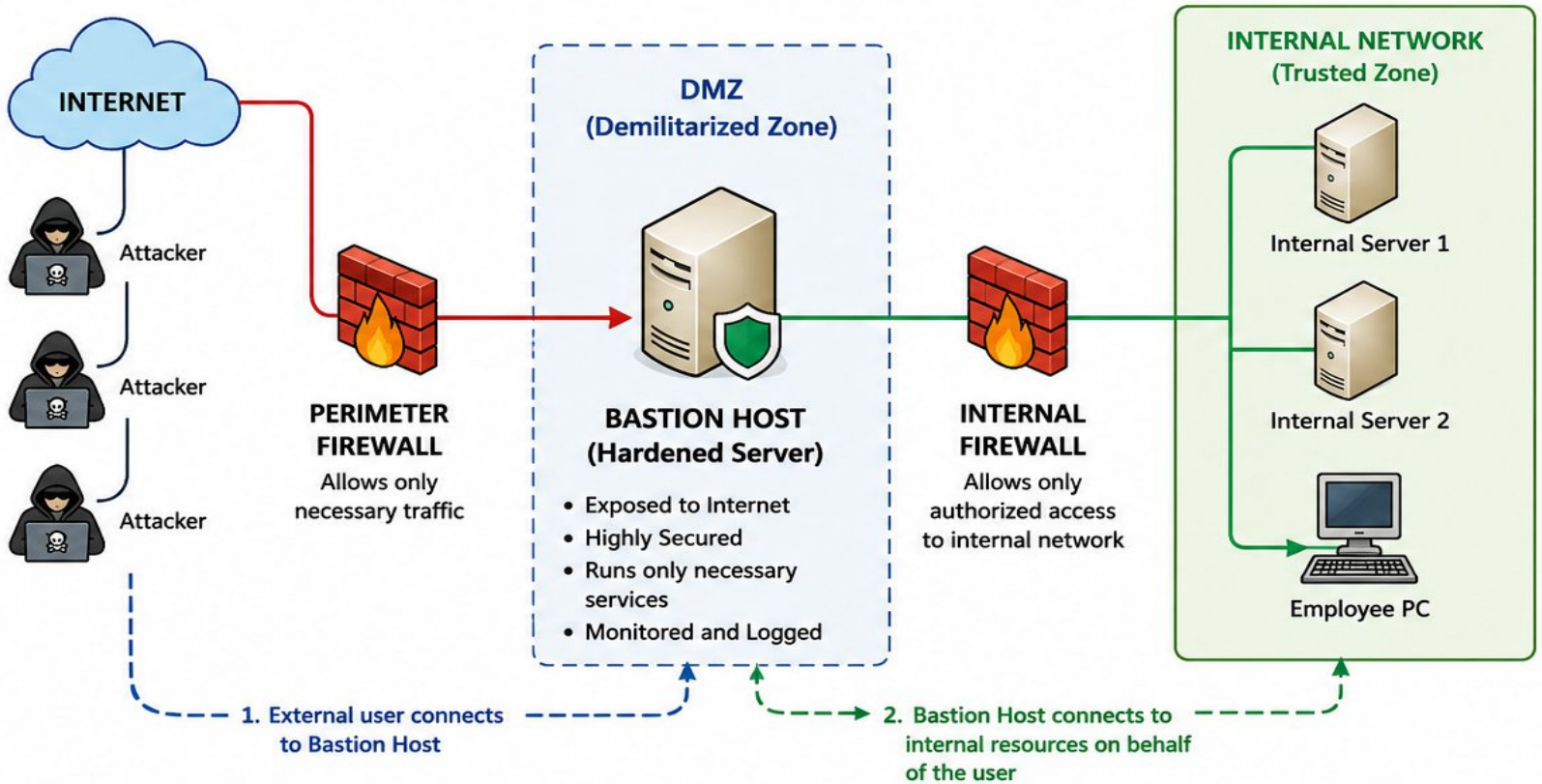
(c) Circuit-level gateway

FIREWALL BASING

Bastion Host

- A **Bastion Host** is a highly secured computer placed at the boundary of a network, usually facing the Internet. It acts as a gateway between external users and the internal network and is hardened with strong security controls to resist attacks. It is often used for proxy, VPN, SSH, or firewall-related services.

BASTION HOST NETWORK ARCHITECTURE



KEY BENEFITS

Stronger Security
Acts as the first line of defense.

Access Control
Central point to control and monitor access.

Logging & Monitoring
All activities are logged for auditing.

Limits Risk
Internal network is hidden from the Internet.

EXAMPLES OF SERVICES ON BASTION HOST

- SSH Server (for remote access)
- Web Proxy
- VPN Server
- Email Gateway
- Firewall / Security Services

HOW IT WORKS

- External users cannot access the internal network directly.
- They must first connect to the Bastion Host.
- Bastion Host validates, logs, and then allows access to internal resources.
- Even if Bastion Host is compromised, internal network remains protected by the Internal Firewall.

LEGEND

- Untrusted Connection (Internet)
- Connection to Bastion Host
- Authorized Connection to Internal Network

BASTION HOST = A Strong, Hardened Gateway between the Internet and Internal Network

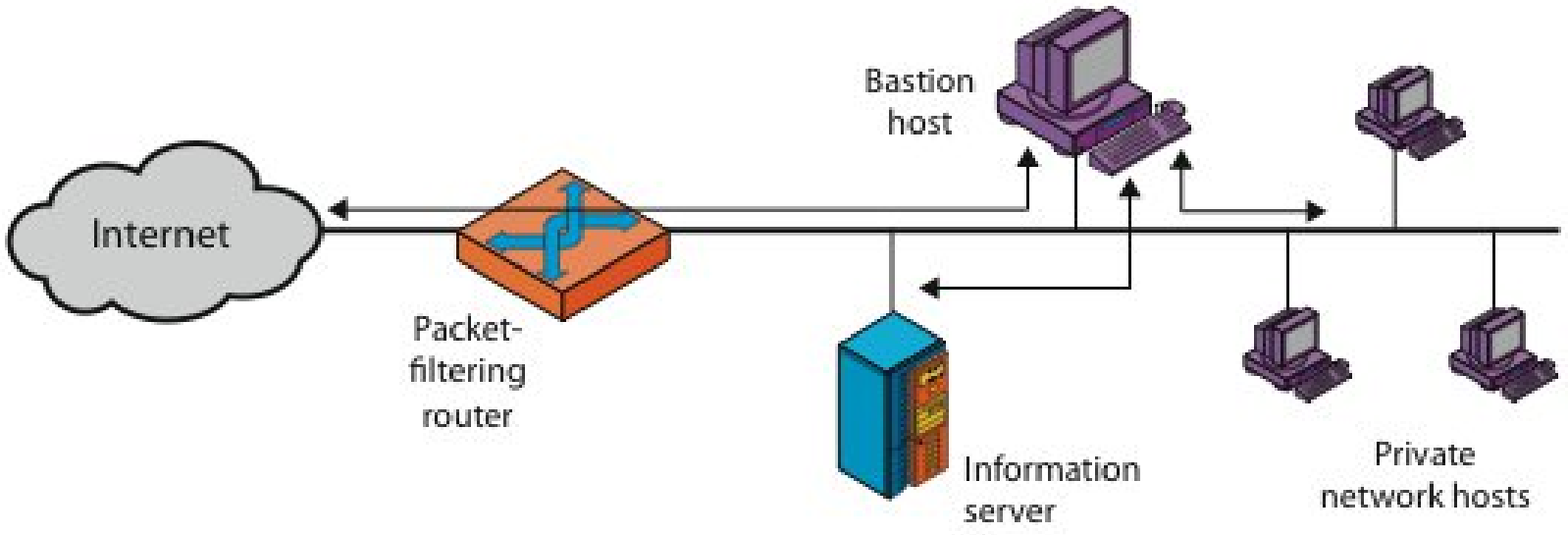
Host-Based Firewalls

- A host-based firewall is a software module used to secure an individual host.
- Such modules are available in many operating systems or can be provided as an add-on package.
- Like conventional stand-alone firewalls, host-resident firewalls filter and restrict the flow of packets.
- A common location for such firewalls is a server.

Personal Firewall

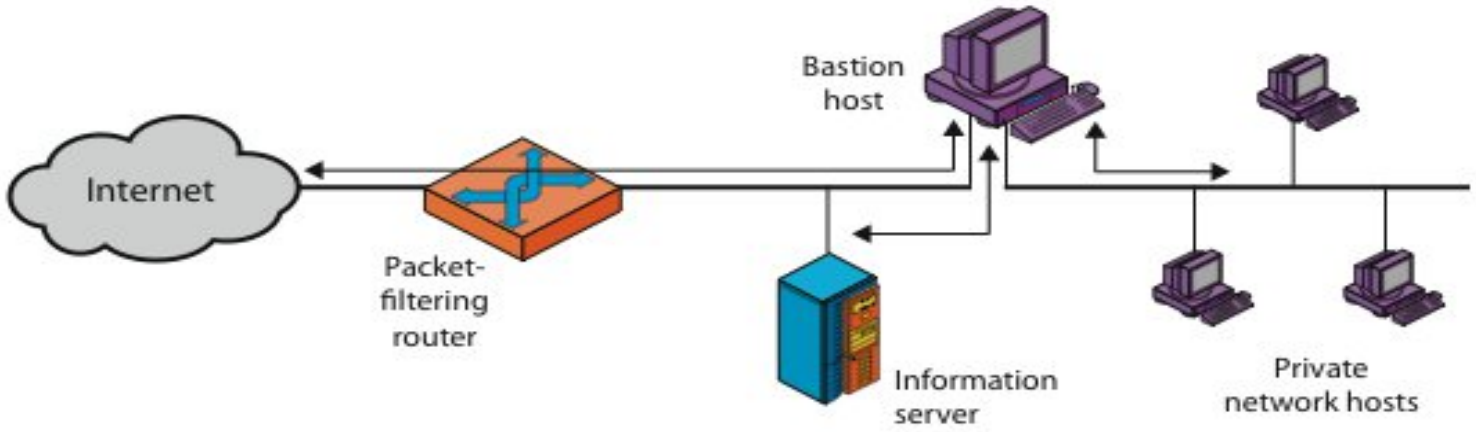
- A personal firewall controls the traffic between a personal computer or workstation on one side and the Internet or enterprise network on the other side.
- Personal fire- wall functionality can be used in the home environment and on corporate intranets.
- Typically, the personal firewall is a software module on the personal computer.
- In a home environment with multiple computers connected to the Internet, firewall functionality can also be housed in a router that connects all of the home computers to a DSL, cable modem, or other Internet interface.

Firewall Configurations



(a) Screened host firewall system (single-homed bastion host)

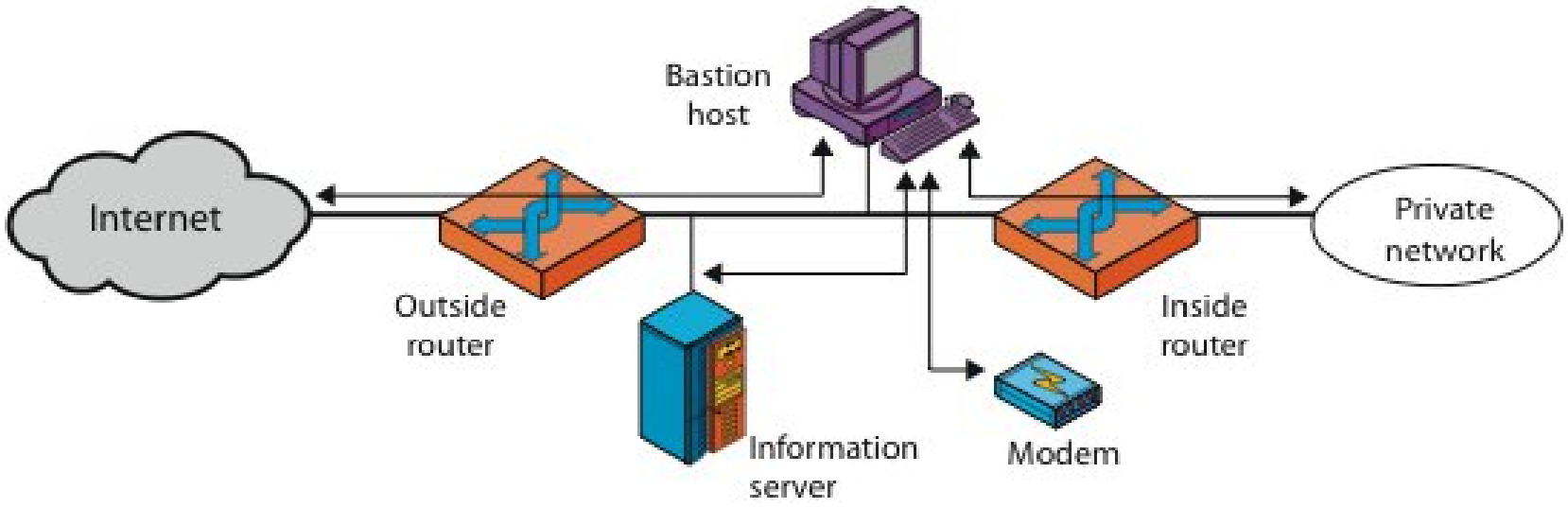
Firewall Configurations



(b) Screened host firewall system (dual-homed bastion host)

A Screened Host Firewall System consists of a packet-filtering router and a bastion host. The router performs initial traffic filtering, while the bastion host acts as a highly secured intermediary between the Internet and the private network. In a dual-homed bastion host configuration, the bastion host has two network interfaces—one connected to the external network and one connected to the internal network—providing an additional layer of security and preventing direct access to internal hosts from the Internet.

Firewall Configurations



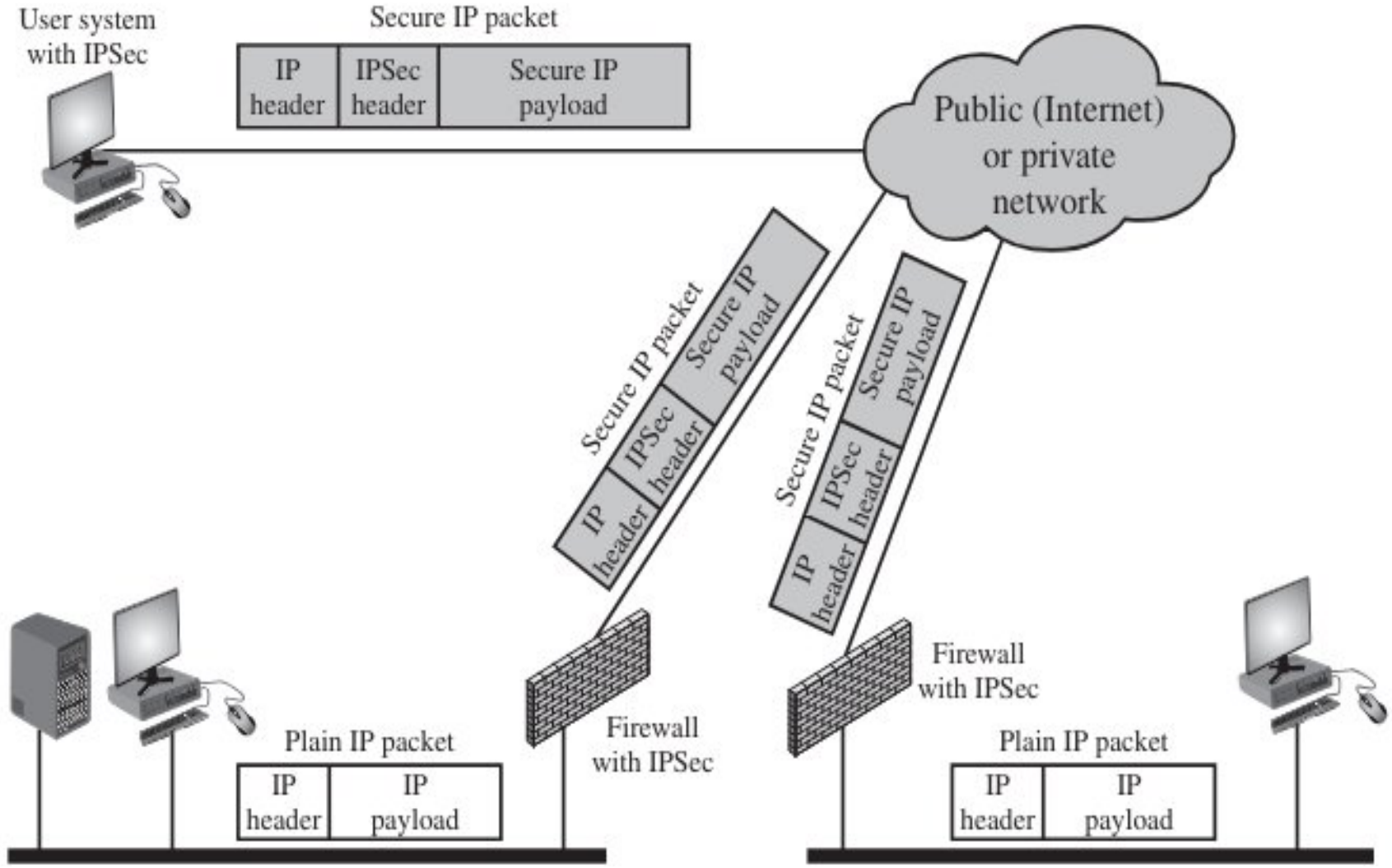
(c) Screened-subnet firewall system

A Screened-Subnet Firewall System uses two packet-filtering routers and a DMZ (screened subnet) between them. Public-facing servers such as bastion hosts and information servers are placed in the DMZ. The outside router protects the DMZ from the Internet, while the inside router protects the private network from the DMZ. This layered architecture provides stronger security than a screened host firewall system.

Firewall Configurations

Virtual Private Network:

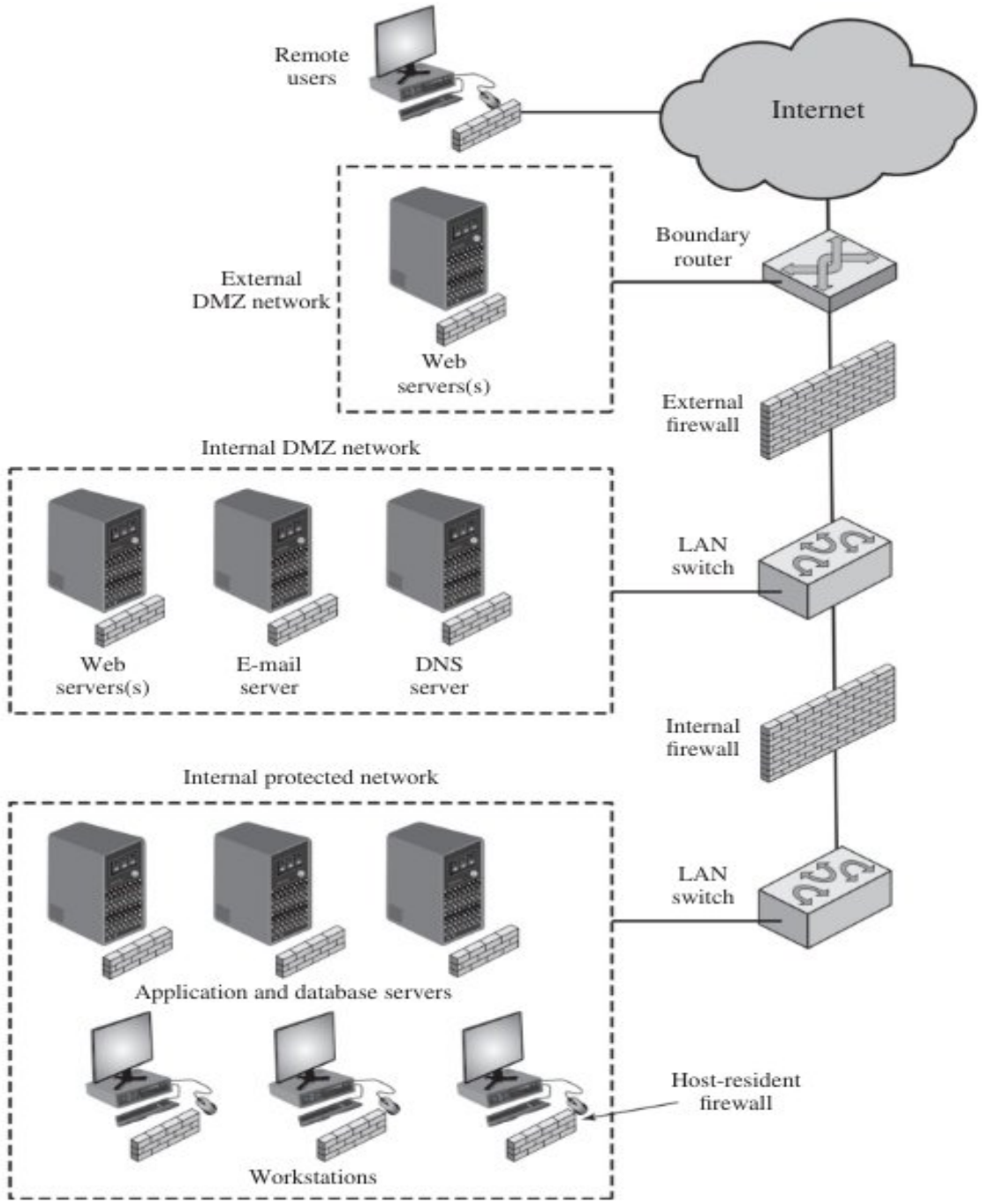
- Uses IPSec (Internet Protocol Security)



Firewall Configurations

Distributed Firewall:

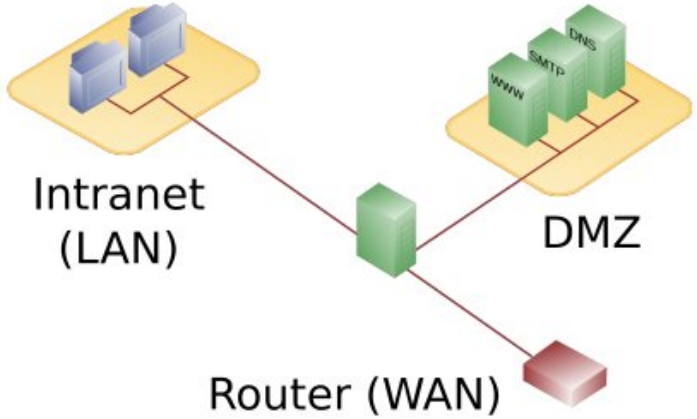
- A distributed firewall configuration involves stand-alone firewall devices plus host based firewalls working together under a central administrative control.
- With distributed firewalls, it may make sense to establish both an internal and an external DMZ. Web servers that need less protection because they have less critical information on them could be placed in an external DMZ, outside the external firewall.

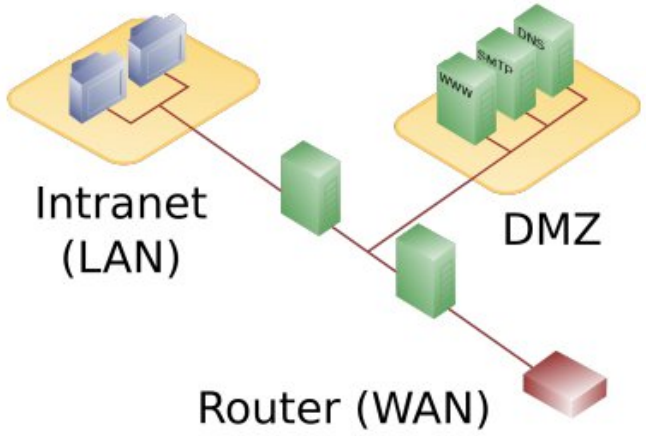


Firewall Locations

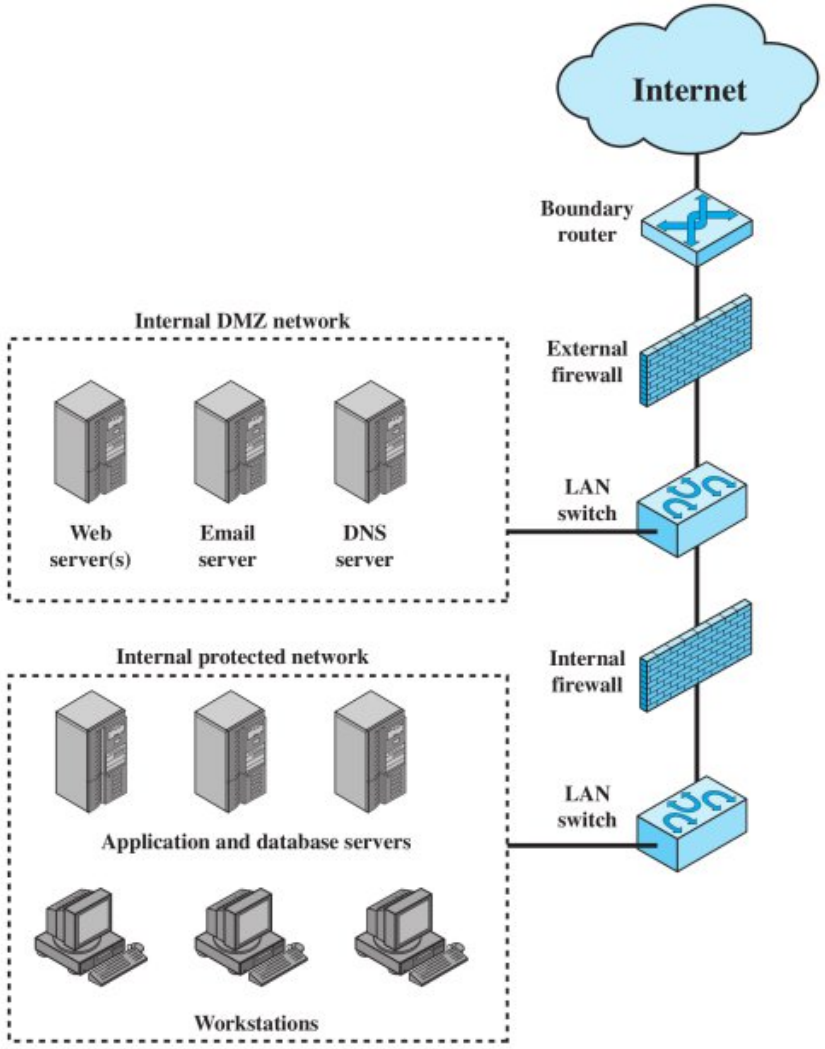
- Firewalls can be located on hosts, including end-users' computers and servers.
- In environments with a large number of users, firewalls are typically placed on network devices that interconnect internal and external networks.
- It is common to divide the internal network into two zones:
  1. Public-facing servers zone, such as web, email, and DNS servers.
  2. End-user computers and internal servers zone, including databases and development web servers.
- Public-facing servers are often placed in a De-Militarized Zone (DMZ) for enhanced security.

Firewall Locations – DMZ with 1 or 2 Firewalls





Firewall Locations – DMZ with 1 or 2 Firewalls



Summary

- Firewall functions:
  - Controls traffic into and out of a network or computer.
  - Implements control based on services, direction, user, and behavior.
- Packet filtering:
  - Accepts or rejects packets based on headers (protocol, source/destination IP, port number).
- Stateful packet inspection:
  - Keeps track of past connections to make more informed decisions.
- Proxy firewalls:
  - Act as intermediaries and relay application or connection traffic between internal and external networks.

Intrusion Detection and Prevention

Intrusion

- **Intrusion:** A purposeful and unauthorized effort to gain access to or manipulate information or systems, with the intention of making them unreliable or unusable.
- **Misuse:** Refers to suspicious activities originating from within the internal network, which can also be categorized as unauthorized or inappropriate use.

Intrusion Detection

- Intrusion detection: The process of monitoring computer system or network events and analyzing them to identify potential incidents. These incidents can involve violations or imminent threats of violation to computer security policies, acceptable use policies, or standard security practices.
- Causes of incidents:
  - Malware: Examples include worms and spyware.
  - Unauthorized access by attackers from the Internet.
  - Misuse of privileges by authorized system users, including attempts to gain unauthorized additional privileges.
- Incidents may not always be malicious:
  - Mistyping the address of a computer, leading to an accidental attempt to connect to a different system without authorization.

Intrusion Detection System

- **Intrusion Detection System (IDS):** Software that automates the process of intrusion detection.
- **Intrusion Prevention System (IPS):** Software that includes all the capabilities of an IDS and can also attempt to prevent potential incidents.
- IDS and IPS technologies share many capabilities, and administrators can typically disable prevention features in IPS products to utilize them as IDSs.
- To simplify terminology, the term Intrusion Detection and Prevention Systems (IDPS) will be used throughout the presentation to refer to both IDS and IPS technologies.

IPS vs IDS

	IPS	IDS
Placement in network infrastructure	Part of the direct line of communication (Inline)	Outside direct line of communication (offline).
System type	Active (monitors and automatically defend) and/or passive.	Passive (monitors and notifies).
Detection mechanism	1. Statistical anomaly-based detection. 2. Signature detection: Exploit-facing signature. Vulnerability-facing signatures.	1. Anomaly based.

Why to use IDPS?

- Primary purpose: Detecting potential incidents.
- Reporting incidents to Security Administrators.
- Recognizing violations of security policies.
- Identifying network traffic violations based on the organization's security policy.
- Monitoring files and identifying suspicious ones.
- Recognizing reconnaissance activities as indicators of an imminent attack.
  - Conducting host or port scans to identify targets for future attacks.
- Blocking reconnaissance activities.

IDS & IPS – Where they differ?

- IPS technologies are differentiated from IDS technologies by one characteristic – IPS response techniques:
  - Stopping the attack:
    - ✓ Terminating the network connection or user session associated with the attack.
    - ✓ Blocking access to the target or potential targets based on the offending user account, IP address, or other attacker attributes.
    - ✓ Blocking all access to the targeted host, service, application, or resource.
  - Changing the security environment:
    - ✓ Modifying the configuration of other security controls, such as network devices (firewalls, routers, switches), to disrupt the attack.
    - ✓ Some IPSs can trigger the application of patches to vulnerable hosts.
  - Modifying the attack's content:
    - ✓ Certain IPS technologies can remove or replace malicious components of an attack to neutralize its impact.
    - ✓ For instance, an IPS can remove an infected file attachment from an email, allowing the cleaned email to reach its intended recipient.

Who is Intruder?

- **Masquerader:** A **Masquerader** is an **unauthorized person (outsider)** who gains access to a computer system by pretending to be a legitimate user, usually by stealing or guessing the user's credentials.
- **Misfeasor:** A legitimate user who accesses data, programs, or resources without authorization or misuses their authorized privileges. Considered an insider.
- **Clandestine user:** An individual who takes control of the system at a supervisory level, evading auditing and access controls or suppressing audit collection. This can be either an insider or an outsider.

Intruder Behavior

- **Cracker:**
  - Motivated by the thrill of access and/or status.
  - Seeks open targets and may share information with others.
  - Exploits security flaws in software to gain unauthorized access.
  - Considers IDS and IPS systems highly useful.
- **Criminal Enterprise:**
  - Motivated by financial rewards and/or political/religious ideologies.
  - Comprised of corporations, government-funded entities, or gangs.
  - Targets specific entities and avoids publicity.
  - Utilizes security flaws and social engineering techniques to gain access.
  - Recognizes the usefulness of IDS and IPS systems.
- **Internal Threat:**
  - Motivated by revenge and/or a sense of entitlement.
  - Has legitimate access to the system, making detection difficult.
  - Internal security mechanisms such as least privilege, strong authentication, logging, auditing, and employee termination policies are useful in mitigating risks.

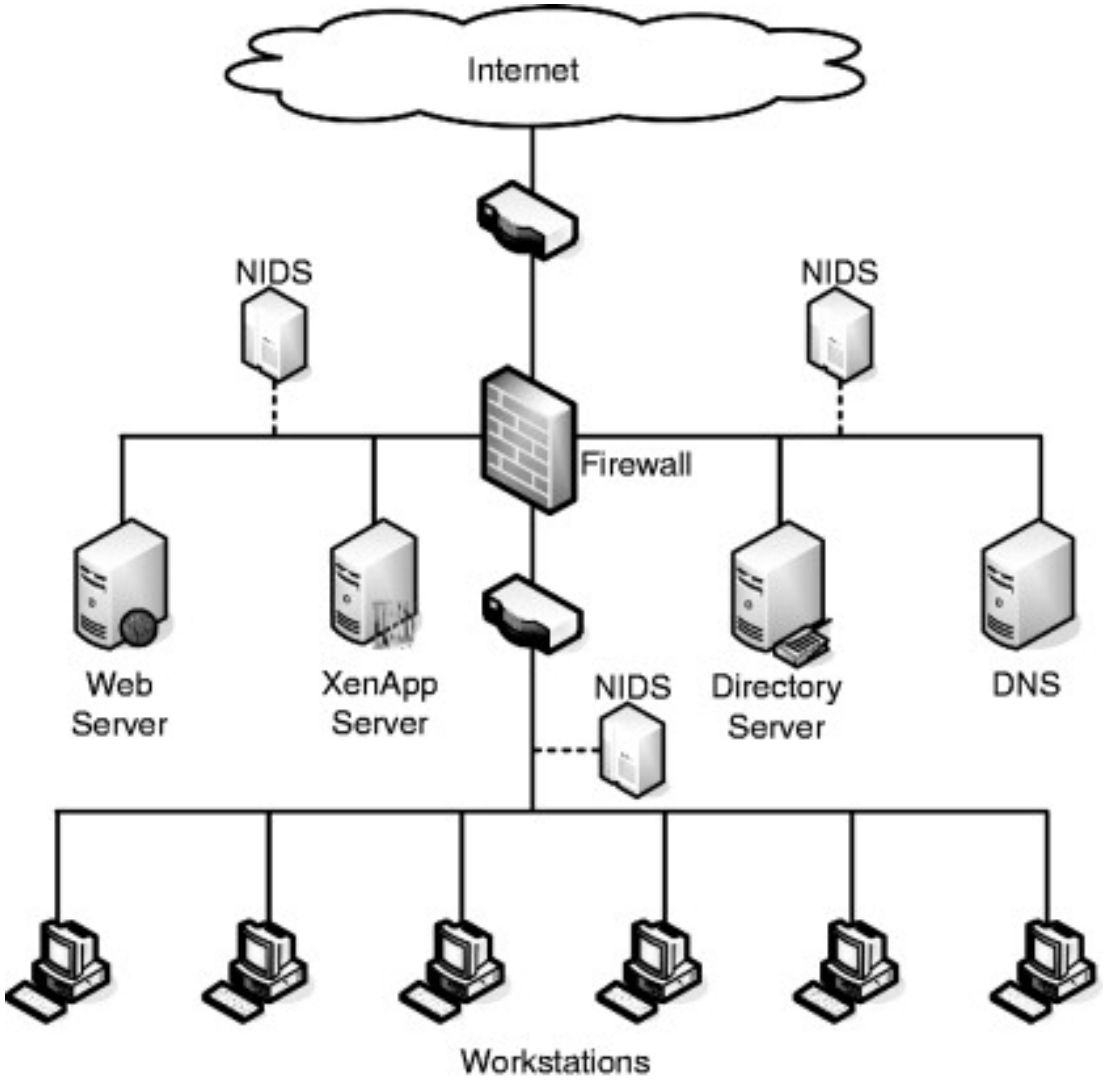
Intrusion Techniques

- **Scanning/Mapping:**
  - **Network Mapping:** Determining the physical connectivity of networks.
  - **Network Enumerating:** Gathering information about a specific machine.
  - **Port scanning/Probing vulnerabilities:** Investigating open ports and searching for potential vulnerabilities.
- **Denial of Service attacks (DoS/DDoS):**
  - **Ping Of Death:** Sending ICMP echo packets with payloads exceeding the maximum limit (65K).
  - **Neptune (SYN FLOOD):** Flooding the target with SYN packets to exhaust system resources.
  - **Land Attack:** Sending a TCP SYN packet with the source IP address set to the target's IP, causing the system to reboot.
  - **Process Table Attack:** Similar to SYN flood, exploiting open connections in Linux.
  - **Smurf Attack:** Flooding the victim machine with a large volume of ping requests.
- **Gaining Access:**
  - **Password Guessing:** Attempting to guess passwords using methods like dictionary attacks or default passwords.
  - **TCP Hijacking:** Involving in the initiation of a TCP session and taking control of it.
  - **Use of agents for destructive purposes:** Employing agents to act on behalf of the attacker in order to harm the target.

Network-based Intrusion Detection Systems (NIDS)

- Network-based Intrusion Detection System (NIDS):
- Detects malicious traffic on a network.
- Requires promiscuous network access to analyze all traffic, including unicast traffic.
- Operates passively without interfering with monitored traffic.
- Typical NIDS architecture involves sniffing the internal interface of the firewall in read-only mode.
- Sends alerts to a NIDS Management server via a separate read/write network interface.
- Inline sensor:
  - Inserted into the network to analyze traffic as it passes through the sensor.
  - Operates as software on existing switches, routers, or firewalls, requiring no additional hardware.
  - Capable of preventing an attack immediately upon detection.
- Passive sensor:
  - Monitors a copy of network traffic.
  - Requires an additional device, such as a switch port mirroring setup, to receive the copy of traffic.
  - Has minimal impact on the performance of the actual traffic being monitored.

Network-based Intrusion Detection Systems (NIDS)

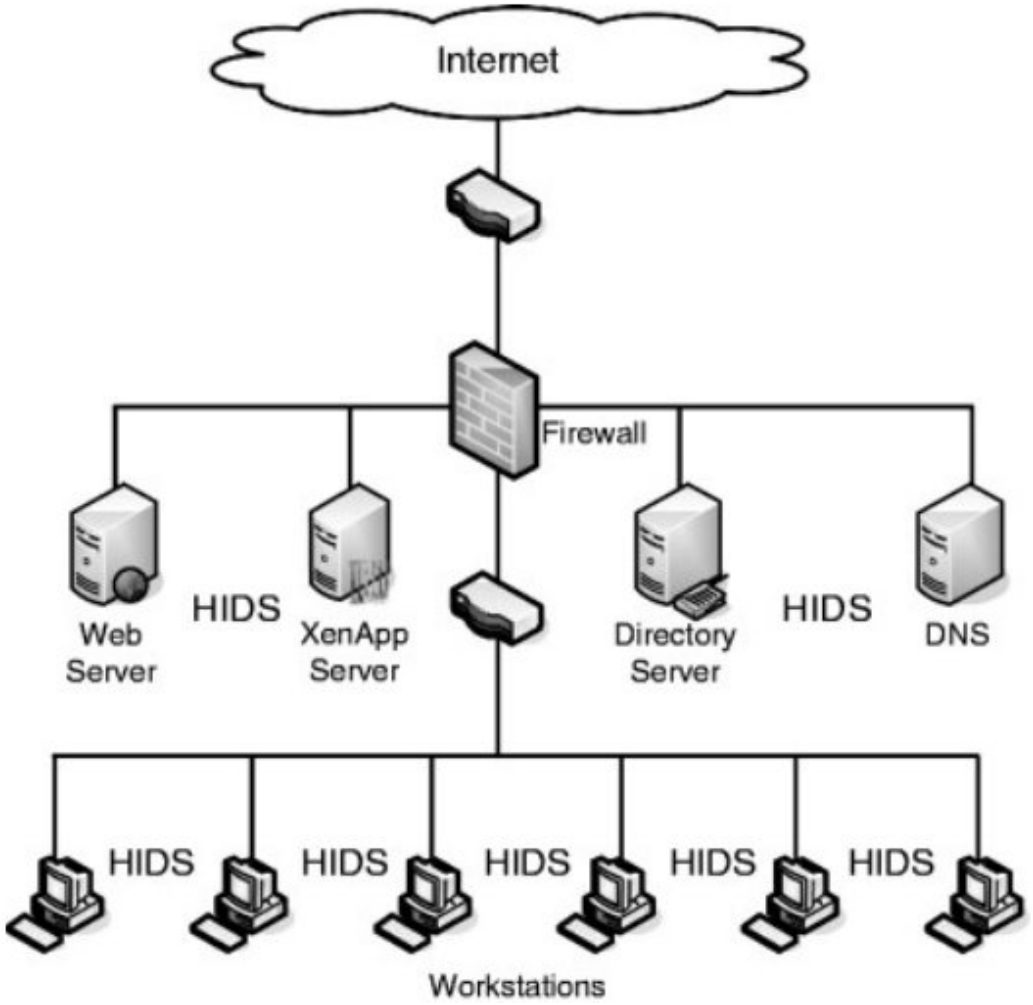


Host-based Intrusion Detection Systems (HIDS)

- HIDS differ from NIDS in two ways.
  - HIDS protects only the host system where it is installed.
  - HIDS checks only its own computer's network traffic, making it faster and compatible with most network cards.
  - HIDS can be installed directly on the firewall to enhance its security.

  - **HIDS allows administrators to enable only the rules relevant to a particular host and disable unnecessary ones.** This improves detection efficiency, reduces CPU usage, and enhances overall system performance.

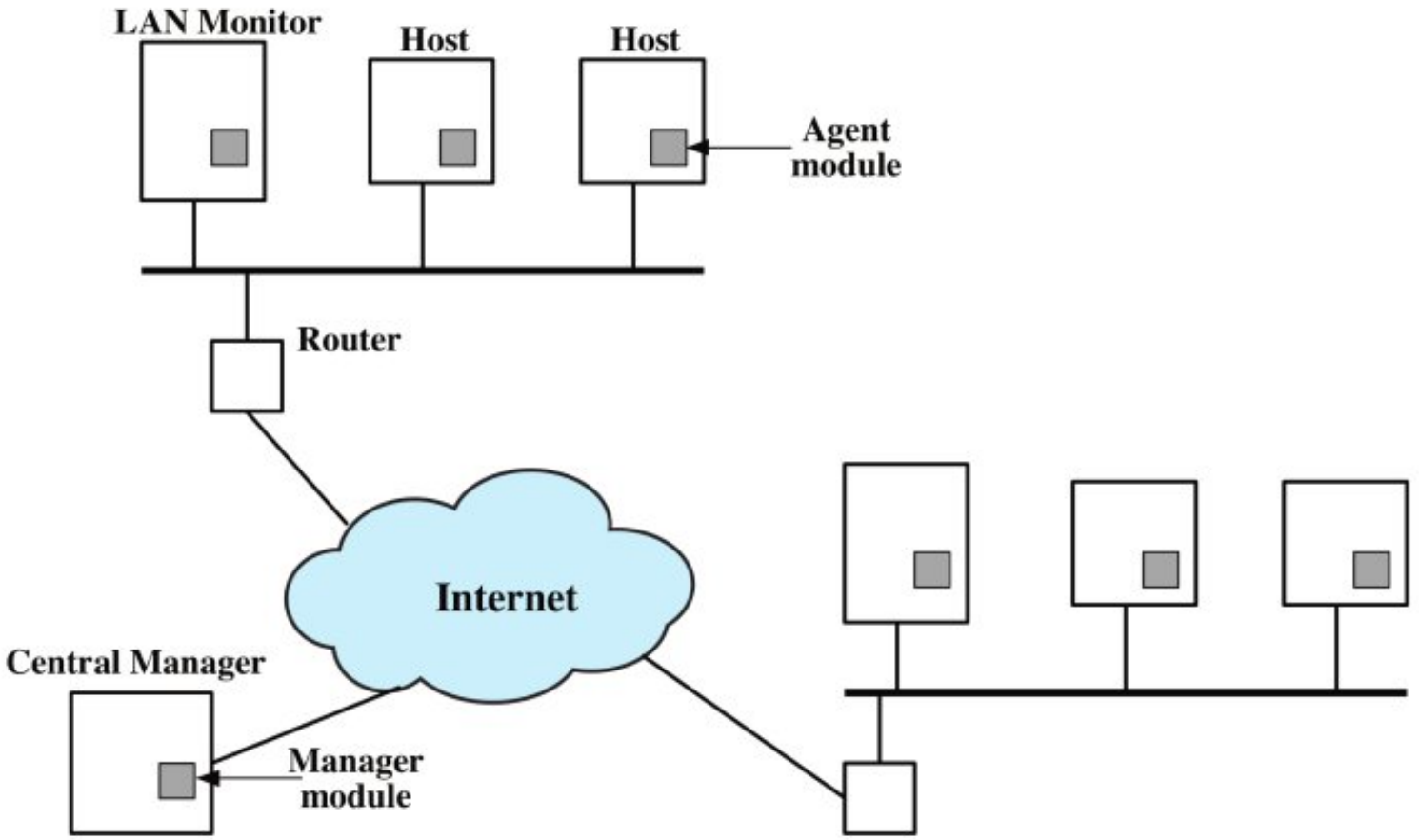
Host-based Intrusion Detection Systems (HIDS)



Distributed Host-Based Intrusion Detection Systems

- Host-based IDS on organizational LAN or internetwork:
  - Host agents installed on individual hosts collect and analyze audit records.
  - LAN monitor agent analyzes LAN traffic.
  - Host and LAN monitor agents send alerts to a central manager.
  - Central manager combines data from agents to detect intrusions and may request specific host data.
- Issues:
  - Dealing with different audit record formats.
  - Ensuring secure transmission of data over the network by agents.
  - Central architecture poses a single point of failure.
  - Distributed architecture requires complex coordination.

Distributed Host-Based Intrusion Detection Systems



Detection Methodologies: Signature based Detection

- Signature Detection:
  - Defines behavior or attacks using a set of rules or patterns.
  - Compares observed behavior against these rules/patterns.
  - **Rule-based anomaly detection:** Defines rules based on past observed normal behavior.
  - **Rule-based penetration identification:** Defines rules based on known attack patterns.

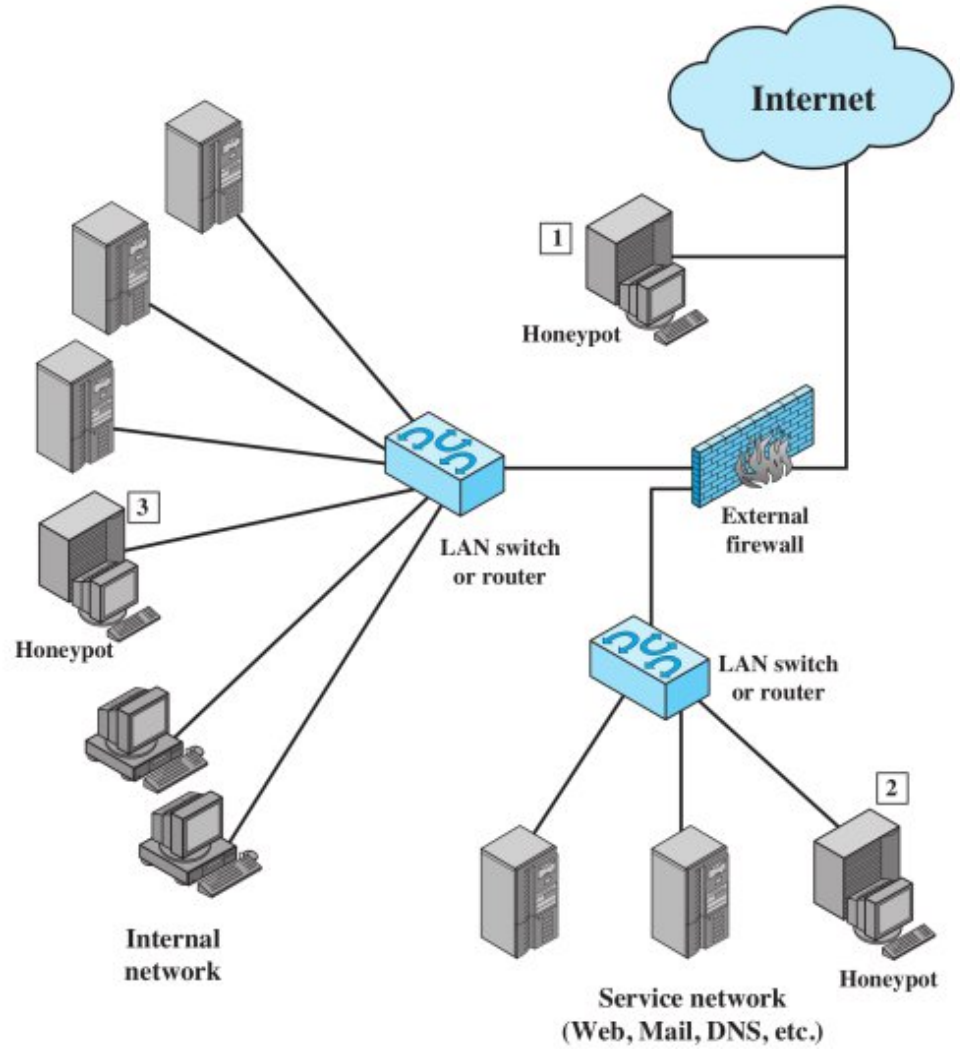
Detection Methodologies: Anomaly based Detection

- Anomaly Detection:
  - Compares observed behavior with previously collected normal behavior.
  - **Threshold detection:** Sets thresholds based on the frequency of event occurrences, regardless of the user.
  - **Profile-based:** Creates and compares user profiles against the observed behavior.

Honeypots

- Decoy systems designed to divert potential attackers away from critical systems.
- Collect information about the attacker's activities and methods.
- Encourage the attacker to remain on the system long enough for administrators to respond.
- Filled with fabricated information that wouldn't be accessed by legitimate users.
- Honeypots have no production value and serve as a resource for monitoring and analysis.
- Incoming communication to a honeypot is likely a probe, scan, or attack.
- Outbound communication from a honeypot indicates that the system has likely been compromised.
- Administrators can observe the intruders' behavior within the honeypot to better understand their tactics and develop defensive measures.

Honeypots Deployment



Summary

- Intruders:
  - Intruders can be insiders (within the organization) or outsiders.
  - Their goal is to gain access to a system or increase their privileges on a system.
  - They exploit software vulnerabilities to acquire protected information.
- Intrusion detection:
  - Its objective is to differentiate between normal behavior and the behavior of an intruder.
  - It looks for anomalies or patterns that indicate potential intrusions.
  - Data collection is performed from one or more hosts or network devices.
- Intrusion prevention:
  - Complements intrusion detection systems.
  - Actively responds to detected threats to prevent intrusions.
  - Stops attacks by terminating connections, blocking access, or modifying the security environment.
  - Some systems can remove or replace malicious components of an attack.
  - Provides an additional layer of defense to enhance overall security.